

AI-Augmented Vulnerability Scanner

Architecture & Reference Implementation Plan

Internal InfoSec / AppSec Tooling

BFSI · IRDAI-regulated · ISO 27001:2022

CONFIDENTIAL — Internal Use Only

Scan-and-report system. No exploitation. Human-gated validation.

Table of Contents

Table of Contents	2
1. Scope, Boundaries & Assumptions	3
1.1 Hard scope (non-negotiable)	3
1.2 Load-bearing assumptions	3
2. Component Diagram & Data Flow	4
2.1 Primary data flow (one scan)	4
3. Tech Stack & LLM Invocation	5
3.1 How the LLM is invoked	5
4. Scanner Adapter Design	6
5. Data Model	7
5.1 SLA rule (encoded as a trigger)	7
6. Secrets, Gray-box Creds & Least Privilege	8
7. Scheduler (Cadence)	8
8. Human-in-the-Loop Gates & Keeping Exploitation Out	9
8.1 Escalation staircase	9
8.2 Exception routing	9
9. Reassessment / Retest & Report Export	9
10. Phased Build Plan	10

1. Scope, Boundaries & Assumptions

1.1 Hard scope (non-negotiable)

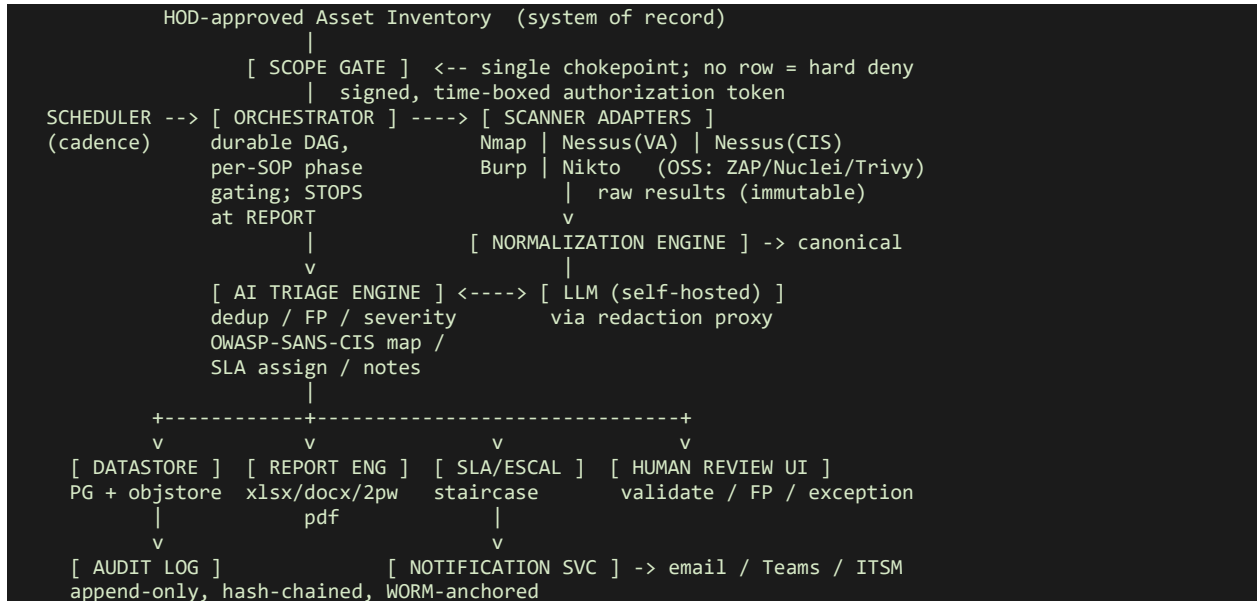
- **Scan and report only.** Detects, triages, reports. No exploitation, lateral movement, or auto-fix.
- **Human-gated validation.** Produces a first-pass triaged result; human testers validate and perform any manual PT downstream.
- **Scope allowlist at every stage.** Refuses any target absent from the HOD-approved asset inventory.
- **Authorized assets only.** All targets are owned by the organization and approved for scanning.

1.2 Load-bearing assumptions

1. **On-prem / private-VPC deployment** inside the data centre — BFSI + IRDAI residency + ISO 27001 push this; egress is allowlisted (SMTP + ITSM only).
2. **Self-hosted LLM** (or a dedicated private endpoint) behind a redaction proxy — finding data does not leave the security enclave.
3. **Hundreds–low-thousands of hosts**, single insurer entity — Postgres-class datastore, not big-data.
4. **Existing identity + vault** (AD/LDAP + SSO, and CyberArk or HashiCorp Vault).
5. **Permanent boundary:** exploitation / lateral movement / auto-remediation are absent from the design, not feature-flagged off.

2. Component Diagram & Data Flow

Components: Scope Gate (authorization service), Scheduler, Orchestrator (durable workflow state machine), Scanner Adapters, Normalization Engine, AI Triage Engine (+ redaction proxy + LLM), Datastore (Postgres + object store), Report Engine, SLA/Escalation Engine, Human Review UI, Notification Service, and an append-only hash-chained Audit Log.



2.1 Primary data flow (one scan)

6. Scheduler fires a scan request (still unauthorized).
7. Scope Gate resolves targets against the approved inventory; mints a signed, time-boxed authorization token (fail closed).
8. Orchestrator runs SOP phases in order; each adapter re-verifies scope at use time (TOCTOU defense).
9. Raw results land in the immutable object store; Normalization canonicalizes them.
10. AI Triage runs deterministic rules first, then a redacted LLM batch pass; findings are deduped, FP-scored, severity-normalized, SLA-stamped, and mapped.
11. Human review gate; then Report and SLA/Escalation engines run. Every transition is audited.

3. Tech Stack & LLM Invocation

Layer	Choice	Justification
Orchestration	Python 3.12 + FastAPI; Temporal	Durable, resumable, auditable workflow state; native phase gating and hard stops.
Datastore	PostgreSQL 16 (pgcrypto, RLS)	Relational integrity across assets-scans-findings-SLAs-exceptions; on-prem, auditable.
Object store	MinIO (S3-compatible) + object-lock	Immutable raw artifacts and reports (evidence).
Reporting	openpyxl, python-docx, WeasyPrint/ReportLab, pikepdf	Pure-Python, no SaaS; pikepdf gives AES-256 dual-password PDF.
Secrets	CyberArk or HashiCorp Vault	Leased, short-lived credentials for gray-box auth contexts.
Identity	AD/LDAP + SAML/OIDC SSO, RBAC	Maps to analyst / manager / CISO / HOD roles.
LLM	Self-hosted model behind redaction proxy	Keeps sensitive recon in-enclave; satisfies ISO 27001 A.5.14 / A.8.12.
Audit	Append-only hash-chained PG table -> WORM	Tamper-evidence for IRDAI / ISO evidence.

3.1 How the LLM is invoked

Deterministic-first, two-stage. The LLM is not the source of truth.

- **Stage A (no LLM):** dedup by composite key, severity from CVSS bands, SLA from severity, and OWASP/SANS/CIS mapping via lookup tables. ~80% of the work, fully reproducible.
- **Stage B (LLM, batch structured-output):** fuzzy cross-tool dedup, false-positive likelihood + rationale, and drafting impact/remediation notes. Constrained JSON schema — not an autonomous tool-calling agent.

Redaction proxy — what is stripped before the prompt: internal IPs/hostnames are pseudonymized (HOST_7, ASSET_42), credentials/sessions are never included, and raw exploit/PoC payloads are excluded (issue type + metadata only). Pseudonyms are re-expanded on return. The LLM cannot upgrade/downgrade severity outside the deterministic band — it can only flag for human review.

4. Scanner Adapter Design

Common contract — **preflight** (re-verify scope), **launch**, **wait**, **fetch_raw** (store immutably), **parse** (-> canonical finding). Every adapter re-checks scope at launch, not just at schedule time.

Engine	Interface	Auth	Notes
Nmap	CLI (-oX XML)	none	Host discovery, port scan, service/version. Safe NSE categories only — no exploit/intrusive/dos.
Nessus Pro	REST API	API keys (vault)	Drives both VA and CIS compliance policies; .nessus XML parsed with defusedxml.
CIS review	Nessus compliance	least-priv audit creds (vault)	Credentialed; annual cadence; results carry CIS control IDs.
Burp Pro	REST API	session profiles per context (vault)	Spider/crawl in 3 auth contexts + automated scan; maps to OWASP.
Nikto	CLI (XML)	optional	Recon + fingerprinting.
OSS variant	ZAP/Nuclei/Trivy	varies	Same phases; swap is config, not code.

5. Data Model

Core tables (full DDL in db/schema.sql). Invariants are enforced at the DB layer, not just in app code:

Table	Purpose & enforced invariant
assets	HOD-approved inventory; the scope gate's source of truth.
scope_authorizations	The gate's ledger; one valid, time-boxed token per scan; stores token hash only.
scans	One pipeline run. phase enum has NO exploit value; report is terminal.
findings	Canonical deduped finding; dup_of links suppressed duplicates; unique dedup_key per scan.
slas	due_date set by TRIGGER from severity (Crit/High +30d, Med/Low +60d). Not hand-editable.
escalations	Day0->Day2->Day4->Day8-10->Day15-20 staircase as trackable rows.
exceptions	Duration->approver routing enforced by CHECK (CISO <=3mo, RMC >3-12mo, Board >12mo).
retests	Closure verification by diff against the prior scan.
audit_log	Append-only, hash-chained (SHA-256); UPDATE/DELETE blocked by trigger.

5.1 SLA rule (encoded as a trigger)

```
due_date := detected_at + (sla_days_for(severity) || ' days')::interval
Critical -> 30 High -> 30 Medium -> 60 Low -> 60
```

6. Secrets, Gray-box Creds & Least Privilege

- **No secret in DB, config, or code.** Adapters lease short-lived credentials from the vault at launch (referenced by creds_ref); leases auto-revoke at scan end.
- **Three web auth contexts** -> three vault paths (unauth [none], min_priv, max_priv). Min/max accounts are purpose-built scanner identities, IP-pinned, rotated per window.
- **Credentialed infra/CIS scans** use least-privilege audit accounts (Windows local-audit, Linux sudo-restricted) — never Domain Admin, never write/exploit rights.
- **Segregated service identities:** the orchestrator can request scan creds but not report-signing keys; the report engine can read PDF passwords but not host creds.
- **PDF passwords** generated per report from the vault and delivered out-of-band.

7. Scheduler (Cadence)

Cadence rule	Schedule
Internal IPs — black-box VA	2x / year (H1 + H2 windows)
Public IPs — gray-box VA	2x / year, offset from internal
CIS configuration review	1x / year
Web app scans	Per SOP cadence, configurable per app

Schedule is not authorization — every scheduled job still passes the scope gate. Target lists resolve against the live inventory at fire time, so newly-approved assets are included and de-approved ones drop out automatically. Blackout calendars protect peak settlement windows.

8. Human-in-the-Loop Gates & Keeping Exploitation Out

12. **Scope gate** is the only entry; re-checked at launch.
13. **Pipeline ends at REPORT.** No exploitation phase exists in the state machine — it is absent, not disabled.
14. **AI triage is advisory.** It cannot suppress findings, change severity outside the band, or close anything.
15. **Manual PT / validation is downstream and human-owned.** The scanner produces inputs to PT, never performs it.
16. **Risk acceptance** requires the correct human approver (CISO / RMC / Board) by duration.
17. **Everything is audited** in the hash-chained log.

8.1 Escalation staircase

Stage	Level	Action
Day 0	Stakeholders	Initial report to stakeholders.
Day 2	Stakeholders	First reminder.
Day 4	+ Manager	Second reminder + manager escalation.
Day 8–10	+ HOD	Third reminder + HOD escalation.
Day 15–20	+ C-suite (ManCom)	HOD + C-suite escalation.

8.2 Exception routing

Duration	Approver	Notes
Up to 3 months	CISO	—
More than 3 months	Risk Management Committee	—
More than 12 months	Board of Directors	Requires reassessment + reapproval, documented risk.

9. Reassessment / Retest & Report Export

Retest flow: a retest scan diffs new findings against the prior scan by dedup_key — fixed -> closure confirmed; still-present -> reopened (SLA clock continues from original detection, no reset); new -> fresh finding + SLA.

Report export: Excel (findings register + SLA dashboard), Word (SOP-format narrative), and PDF. The PDF is encrypted with two passwords — a user password to open and an owner password (copy/modify/print disabled). Passwords are vault-sourced and delivered out-of-band.

10. Phased Build Plan

Phase	Duration	Deliverable / exit criteria
0 — Foundations	2–3 wks	Schema, scope gate + inventory import, vault, hash-chained audit, RBAC/SSO, Temporal skeleton. Exit: authorize/deny works; all actions audited.
1 — Infra MVP	3–4 wks	Nmap + Nessus(VA), normalization, deterministic triage (dedup+severity+SLA), Excel report. Exit: end-to-end internal black-box scan, human-validated.
2 — Web MVP	3–4 wks	Nikto + Burp, 3 auth contexts, OWASP/SANS maps, Word + 2-password PDF. Exit: web pipeline parity.
3 — AI triage	3 wks	Redaction proxy + self-hosted LLM, batch dedup/FP/notes reconciled to bands. Exit: measurable FP reduction with explainability.
4 — Governance	3 wks	Escalation staircase, exception routing, retest/diff, notifications + ITSM, scheduler cadence. Exit: full lifecycle running.
5 — OSS + hardening	2–3 wks	ZAP/Nuclei/Trivy at parity, pen-test of the tool itself, ISO 27001 evidence pack, DR/backup. Exit: audit-ready.

Open item that could change the architecture: the design assumes a self-hosted LLM inside the enclave. A managed/cloud LLM would make the redaction proxy a hard compliance control and add a DPIA + no-train/no-retain attestation, but the component shape is unchanged.